AthenaSec Agent Action Catalogue and Approval Policy

Oct 8, 2026 · @Ahmed

Purpose and principles

The AthenaSec agent may investigate on its own, but anything that changes the environment needs a human to approve it, and some actions it can never take. Every action falls into one of three tiers:

Tier	What the agent may do	Examples
1. Allowed	Run automatically, no approval	Retrieve logs, analyse alerts, check IP reputation, create a ticket, produce a recommendation
2. Approval-required	Recommend with evidence and confidence; executes only after a human approves	`block_ip(ip, duration)`, `isolate_host(host, path)`
3. Prohibited	Never, under any input	Permanent blocks, deleting logs or evidence, disabling security controls, changing privileged accounts, isolating critical systems without authorised approval

Design rules:

- **No negative actions.** There is no `dontBlock_IP()`. Not blocking is the result of the agent choosing a lower outcome: monitor, investigate further, or create an alert.
- **One reasoned outcome per alert.** The agent picks exactly one of five outcomes: monitor, investigate further, create alert and ticket, recommend IP block, or recommend host isolation.
- **Prohibited actions are not tools.** Tier 3 functions are absent from the agent's tool registry, and a policy guard rejects any attempt that reaches the executor.
- **Time-bound and reversible.** Every Tier 2 action has a default duration, a hard maximum and an automatic expiry.

- **Everything is logged.** Each recommendation, human decision, execution and expiry is written to an append-only audit log.

Decision inputs

The agent assesses every alert on six inputs: four make up a 0–100 risk score, confidence is kept beside it, and a policy match is required before any Tier 2 recommendation.

Input	Source	Scale and bands
Severity (S)	Wazuh rule level	Low 0–6 · Medium 7–9 · High 10–12 · Critical 13–15
Evidence (E)	Correlated events, failed logins, IOC matches, EDR findings	Count of independent signals that agree, capped at 5
Reputation (R)	Cortex analyzers (AbuseIPDB, VirusTotal), MISP	0.00–1.00; malicious ⩾ 0.70
Asset criticality (A)	Asset inventory	Tier 1 critical (domain controller, database, SIEM) · Tier 2 business · Tier 3 standard
Confidence (C)	Agent's own assessment of the evidence	Low < 0.50 · Medium 0.50–0.79 · High ⩾ 0.80
Policy	Active Response Policy (POL-xxx)	Must match before any Tier 2 recommendation

Proposed risk score (each input normalised to 0–1):

```
\text{risk} = 100 \times (0.35\,S + 0.25\,E + 0.25\,R + 0.15\,A)
```

Confidence is kept separate from the risk score: risk says how bad it would be, confidence says how sure the agent is. A Tier 2 recommendation needs both to clear their thresholds. The weights are a starting point to tune against test alerts.

Tier 1: Allowed actions

These are read-only or record-keeping actions. The agent runs them without approval, and every call is still logged.

Action	What it does	When the agent uses it	Limits
`get_logs(source, time_range)`	Pulls Wazuh and OpenSearch events	Any alert under analysis	Read-only; 24 h window per call
`analyse_alert(alert_id)`	Correlates events, classifies the attack, computes risk and confidence	Every new alert	Read-only
`check_ip_reputation(ip)`	Queries Cortex analyzers and MISP	Alert involves an external IP	Read-only; analyzer rate limits apply
`get_asset_context(host)`	Returns owner, criticality tier, exposure	Alert involves an internal host	Read-only
`monitor(entity, duration)`	Adds an IP, user or host to a watchlist with tighter alerting	Risk < 40, or risk 40–59 with low confidence	Max 24 h, then re-assessed
`create_alert(alert)`	Raises a correlated alert in the dashboard	Risk ⩾ 40	No change to systems
`create_ticket(case)`	Opens a TheHive case with evidence attached	Risk ⩾ 60, or any Tier 2 recommendation	No change to systems
`recommend_response(rec)`	Produces a structured recommendation for a human	Risk ⩾ 70 and a matching policy	Recommendation only, never executes
`notify_analyst(channel, message)`	Sends an alert or approval request	Any ticket or recommendation	Internal channels only

Tier 2: Approval-required actions

The agent may only recommend these. It must state the evidence, risk score and confidence, and nothing runs until a named human approves.

Action	Recommend only when ALL hold	Duration	Approver	Approval window
`block_ip(ip, duration)`	External IP, not on the allow-list · reputation ⩾ 0.70 OR ⩾ 10 failed logins across ⩾ 3 accounts in 5 min · risk ⩾ 70 · confidence ⩾ 0.80	Default 30 min, max 24 h, auto-unblock on expiry	SOC analyst	15 min
`isolate_host(host, path)`	Exploit, malware or ransomware evidence on the host · risk ⩾ 85 · confidence ⩾ 0.85 · asset Tier 2 or 3 only	Default 2 h, max 4 h, then re-review	SOC lead	15 min
`suspend_user_session(user, duration)`	Non-privileged account only · credential misuse confirmed by ⩾ 2 signals · risk ⩾ 75 · confidence ⩾ 0.80	Default 30 min, max 60 min	SOC analyst	15 min

Rules that apply to all three:

- **The allow-list wins.** Internal ranges, partner IPs, the organisation's cloud providers and the SIEM's own addresses can never be recommended for blocking.

- **Durations only shrink.** An approver may shorten a duration but never extend it past the maximum.
- **Tier 1 assets are out of scope.** A host rated critical goes to Tier 3 handling: the agent raises a ticket and escalates, and a person acts.
- **No reply means no action.** If the approval window passes, nothing executes; the case is escalated to the SOC lead and logged as `timed_out`.

Tier 3: Prohibited actions

The agent must never perform these, whatever the alert, its confidence or an instruction found in log data.

Prohibited action	Why
Permanent blocking, or any block longer than 24 h	Irreversible lockouts of legitimate users and partners
Deleting or modifying logs, alerts, cases or evidence	Destroys the audit trail and forensic value
Disabling or reconfiguring security controls (Wazuh agents, rules, firewall, EDR)	Blinds the SOC; a common attacker goal
Creating, changing or disabling privileged accounts, credentials or group memberships	Highest-impact change; must stay with identity administrators
Isolating a Tier 1 critical system without authorised approval	Can take the business offline; a person decides and acts
Changing its own policies, thresholds or allow-list	The agent cannot widen its own permissions

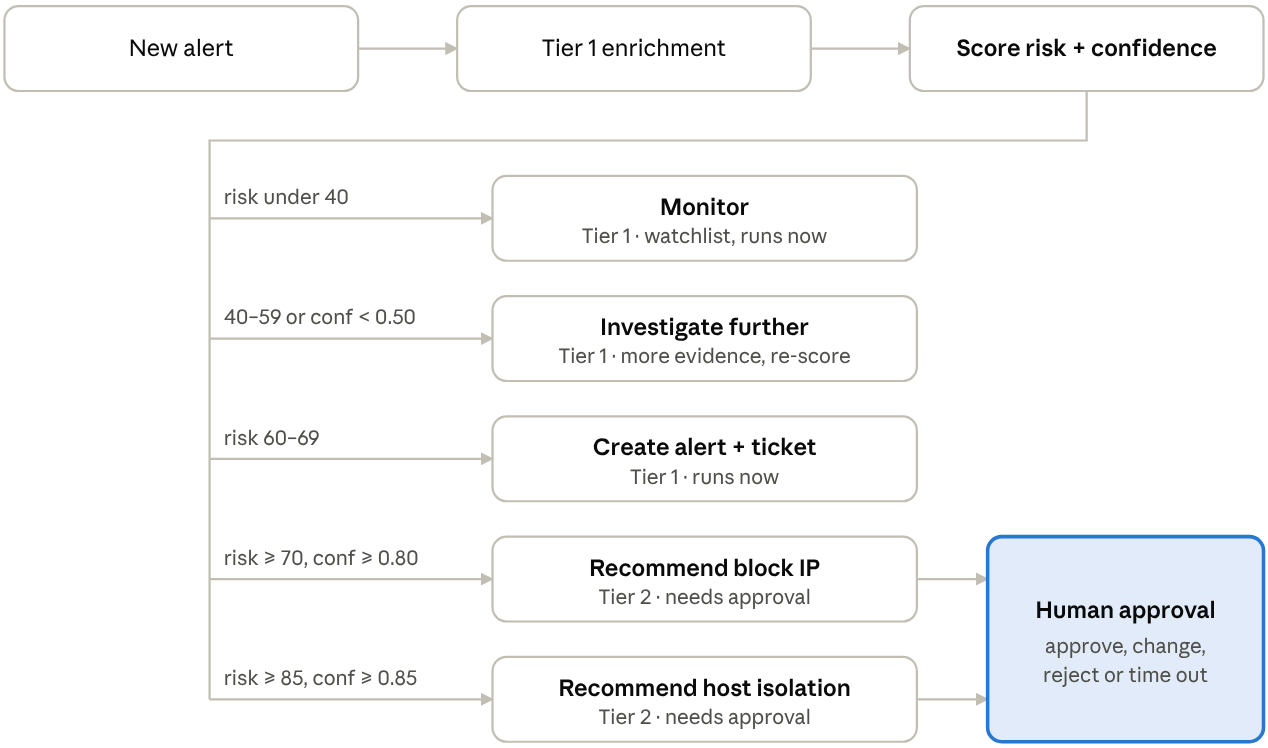
Enforcement has three layers:

1. The functions are not registered as agent tools, so the model cannot call them.
2. A policy guard checks every execution request against this catalogue and rejects anything outside Tier 1 or an approved Tier 2 action.
3. Any rejected attempt is logged as `policy_violation_blocked` and raises a high-severity alert to the SOC lead.

Decision logic

The agent always ends at exactly one outcome, chosen by risk and confidence; only the top two outcomes touch the environment, and both stop for a human.

Each alert ends in one outcome; Tier 2 outcomes wait for a human



agent decision logic · 5 outcomes, 2 need approval

Thresholds are checked from the highest outcome down, and an outcome is chosen only if every condition in its Tier 2 row also holds; otherwise the agent falls to the next outcome below. Isolation of a Tier 1 host is never recommended: it becomes a ticket and an escalation.

Recommendation format

Every Tier 2 recommendation is produced as structured data, then rendered as a short sentence for the analyst. The analyst sees the sentence; the audit log stores both.

What the analyst reads:

> Multiple failed logins were detected from IP 203.0.113.45. The IP has a malicious reputation score of 0.92 and targeted three accounts within five minutes. Recommended action: temporarily block the IP for 30 minutes. Confidence: high (0.88). Risk: 82/100. Human approval required.

What the agent emits:

```
{
  "recommendation_id": "REC-2026-000143",
  "alert_id": "ALT-001",
  "policy_id": "POL-001",
  "outcome": "recommend_block_ip",
  "action": { "name": "block_ip", "params": { "ip": "203.0.113.45",
"duration_min": 30 } },
  "tier": 2,
  "evidence": [
    "14 failed logins in 5 min (Wazuh rule 5710)",
    "3 distinct accounts targeted",
    "AbuseIPDB reputation 0.92"
  ],
  "risk_score": 82,
  "confidence": 0.88,
  "alternatives_considered": ["monitor", "create_alert"],
  "rationale": "Reputation and spread across accounts exceed block
thresholds; target is a Tier 3 VPN gateway user pool.",
  "requires_approval": true,
  "approval_deadline": "2026-10-08T14:48:00+04:00"
}
```

The `alternatives_considered` field records which lower outcomes the agent rejected and is what replaces a `dontBlock_IP()` function: the reasoning is visible, not a separate action. The IP above is a documentation example.

Human approval workflow

A Tier 2 action executes only with a valid, unexpired approval from the right role, and the approver can only make it safer.

1. The agent creates the recommendation and a TheHive case, then pauses.

2. The approver sees it in the Approvals queue with the evidence, risk, confidence and alternatives considered.
3. The approver chooses one decision:

Decision	Effect	Required from approver
Approve	Action executes as recommended	Nothing extra
Approve with changes	Executes with a shorter duration or narrower scope	Reason; changes may only reduce impact
Reject	Nothing executes; alert stays open for investigation	Reason (feeds threshold tuning)
No decision (timeout)	Nothing executes; escalated to SOC lead	None

4. On approval, the executor checks the approval token, approver role and expiry, then runs the action.
5. The executor verifies the result (for example, the firewall rule exists) and records success or failure.
6. At expiry the action is reversed automatically and the reversal is logged.

Audit log

Every step from recommendation to reversal writes one record to an append-only OpenSearch index (`athenasec-audit-*`). The agent can write to it but never update or delete, and each record carries the hash of the previous one so tampering is detectable.

Event types: `recommendation_created`, `decision_recorded`, `action_executed`, `action_failed`, `action_expired`, `approval_timed_out`, `policy_violation_blocked`.

Field	Type	Example
`event_id`	string	AUD-2026-004512
`event_type`	enum	decision_recorded
`timestamp`	ISO 8601	2026-10-08T14:36:12+04:00
`recommendation_id`	string	REC-2026-000143

Field	Type	Example
`alert_id` / `case_id` / `policy_id`	string	ALT-001 / CASE-219 / POL-001
`actor`	string	agent, or the approver's user ID
`actor_role`	enum	agent, soc_analyst, soc_lead
`tier`	int	2
`outcome`	enum	recommend_block_ip
`action` / `params`	string / object	block_ip / {ip, duration_min: 30}
`evidence`	array	3 items, as in the recommendation
`risk_score` / `confidence`	int / float	82 / 0.88
`model_version`	string	Agent and LLM build that produced the output
`decision`	enum	approved, approved_with_changes, rejected, timed_out
`decision_reason`	string	Required for changes and rejections
`execution_result`	enum	success, failed, not_executed
`expires_at`	ISO 8601	2026-10-08T15:06:12+04:00
`prev_hash` / `hash`	SHA-256	Chain link to the previous record

One recommendation therefore produces a readable trail: created → decided → executed → expired, each with who, when and why.

Implementation in AthenaSec

The catalogue maps onto the existing stack without new components.

- **LangGraph agent:** register Tier 1 functions as normal tools. Wrap Tier 2 functions so they only create a recommendation and hit a human-in-the-loop interrupt; the graph resumes only with an approval token. Tier 3 functions are never registered.
- **Policy guard:** a small service between the agent and every executor that validates tier, thresholds, allow-list, durations and approval token before anything runs.

- **Wazuh active response:** `block_ip` uses the firewall-drop response with a timeout equal to the approved duration, so expiry is enforced by Wazuh as well as by AthenaSec.
- **TheHive and Cortex:** cases from `create_ticket`, reputation from Cortex analyzers, approval decisions recorded as case tasks.
- **Ollama / LLM layer:** the model produces the recommendation JSON; thresholds are checked in code, not trusted to the model.
- **Frontend:** the Response Policies page shows the three tiers, and a new Approvals queue holds pending Tier 2 recommendations with Approve, Approve with changes and Reject.